

Politica de Privacidad y Evaluacion de Impacto en la Proteccion de Datos (EIPD)

Sistema: Goya Ledger – Infraestructura de Clave Publica (PKI) y Firma Electronica sobre Blockchain

Version del documento: 1.0

Fecha de emision: 2026-08-13

Clasificacion: Confidencial – Uso interno y regulatorio

Estado: Vigente

Proxima revision programada: 2027-08-13

Tabla de contenidos

1. Introduccion y alcance
 2. Marco normativo
 3. Responsable del tratamiento
 4. Datos personales tratados
 5. Finalidad del tratamiento
 6. Base legal del tratamiento
 7. Evaluacion de impacto en la proteccion de datos (EIPD)
 8. Derechos ARCO
 9. Transferencia internacional de datos
 10. Retencion y eliminacion de datos
 11. Medidas de seguridad
 12. Notificacion de brechas de seguridad
 13. Delegado de proteccion de datos
 14. Disposiciones finales
 15. Anexo A – Registro de actividades de tratamiento
 16. Anexo B – Matriz de riesgos
 17. Anexo C – Glosario
-

1. Introduccion y alcance

1.1 Proposito

El presente documento establece la Politica de Privacidad y la Evaluacion de Impacto en la Proteccion de Datos (EIPD) del sistema **Goya Ledger**, una infraestructura de clave publica (PKI) y firma electronica construida sobre tecnologia blockchain. Su objetivo es garantizar que todo tratamiento de datos personales realizado por el sistema cumpla con la legislacion chilena e internacional aplicable, resguardando los derechos fundamentales de los titulares de datos.

1.2 Alcance

Esta politica aplica a:

- **Componentes del sistema:** Nodo completo (Full), cliente liviano (Light), aplicacion de escritorio (Tauri), API REST (/api/v1), red P2P, y todos los modulos internos del codigo fuente.
- **Datos tratados:** Toda informacion personal procesada por el sistema, incluyendo datos de identidad, biometricos, criptograficos, de auditoria y credenciales digitales.
- **Actores:** Suscriptores (firmantes), partes confiantes (verificadores), oficiales de la Autoridad de Registro (RA), administradores del sistema y delegados de proteccion de datos.
- **Ambitos geograficos:** Operaciones en la Republica de Chile y, cuando aplique, tratamientos sujetos al Reglamento General de Proteccion de Datos de la Union Europea (GDPR).
- **Ciclo de vida completo:** Desde la recoleccion de datos en el proceso de proofing de identidad hasta su eliminacion o anonimizacion conforme a los plazos de retencion establecidos.

1.3 Documentos relacionados

Documento	Ubicacion
Politica de Certificacion (CP)	docs/policy/CP.md
Declaracion de Practicas de Certificacion (CPS)	docs/policy/CPS.md
Plan de Seguridad	docs/policy/PLAN-SEGURIDAD.md
Plan de Contingencia	docs/policy/PLAN-CONTINGENCIA.md
Acuerdo de Suscriptor	docs/policy/ACUERDO-SUSCRIPTOR.md
Acuerdo de Parte Confiante	docs/policy/ACUERDO-PARTE-CONFIANTE.md
Cumplimiento de Firma Electronica	docs/compliance/ELECTRONIC-SIGNATURE-COMPLIANCE.md
Guia de Configuracion	docs/api/configuration-guide.md

2. Marco normativo

2.1 Legislacion chilena

2.1.1 Ley 19.628 sobre Proteccion de la Vida Privada

Ley marco de proteccion de datos personales en Chile. Establece:

- **Artículo 4:** El tratamiento de datos personales solo puede efectuarse cuando la ley o el titular consientan expresamente en ello.
- **Artículo 9:** Los datos personales deben utilizarse solo para los fines para los cuales hubieren sido recolectados.
- **Artículo 10:** Los responsables de registros o bancos de datos personales no pueden proporcionar la informacion a personas no autorizadas.
- **Artículo 12:** Derecho de acceso del titular a sus datos.
- **Artículos 6 y 7:** Regimen especial para datos sensibles (incluye datos biometricos).

2.1.2 Ley 19.799 sobre Documentos Electronicos, Firma Electronica y Servicios de Certificacion

- **Artículo 15:** Los prestadores de servicios de certificacion (PSC) deben garantizar la proteccion de los datos personales de los suscriptores, adoptando las medidas de seguridad tecnicas y organizativas necesarias. El modulo de Autoridad de Registro (src/identity/ra.rs) implementa el proceso de verificacion de identidad (proofing) exigido por este articulo.
- **Artículo 16:** Obligacion de confidencialidad respecto de la informacion proporcionada por los suscriptores.
- **Artículo 17:** Obligacion de mantener un registro de certificados emitidos accesible al publico.

2.1.3 Decreto Supremo 181 (Reglamento de la Ley 19.799)

- **Artículo 13:** Requisitos de seguridad para PSC acreditados.
- **Artículo 15:** Procedimientos de verificacion de identidad presencial.
- **Artículo 38:** Obligacion de notificar incidentes de seguridad a la Subsecretaria de Economia dentro de **24 horas** de detectada la brecha.
- **Artículo 47:** Conservacion de registros de auditoria por un minimo de **6 anos** desde la expiracion del ultimo certificado emitido (el sistema aplica 7 anos como margen de seguridad).

2.2 Legislacion de la Union Europea

2.2.1 Reglamento General de Proteccion de Datos (GDPR) – Reglamento (UE) 2016/679

Aplicable cuando el sistema trate datos de personas ubicadas en la UE o cuando se ofrezcan servicios de certificacion a suscriptores europeos.

- **Artículo 5:** Principios relativos al tratamiento (licitud, lealtad, transparencia; limitacion de la finalidad; minimizacion de datos; exactitud; limitacion del plazo de conservacion; integridad y confidencialidad).
- **Artículo 6:** Bases legales del tratamiento.
- **Artículo 9:** Tratamiento de categorias especiales de datos (biometricos).
- **Artículos 13 y 14:** Informacion que debe proporcionarse al interesado.
- **Artículos 15 a 22:** Derechos del interesado (acceso, rectificacion, supresion, limitacion, portabilidad, oposicion).
- **Artículo 25:** Proteccion de datos desde el diseno y por defecto.
- **Artículo 35:** Obligacion de realizar EIPD cuando el tratamiento entrane un alto riesgo.
- **Artículo 33:** Notificacion de brechas a la autoridad de control en **72 horas**.
- **Artículo 44 y siguientes:** Transferencias internacionales de datos.

2.2.2 Reglamento eIDAS – Reglamento (UE) 910/2014

- **Artículo 5:** No discriminacion de documentos electronicos.
- **Artículo 19:** Requisitos de seguridad para prestadores de servicios de confianza.
- **Artículo 24:** Verificacion de identidad para certificados cualificados.
- **Considerando 11:** Los servicios de confianza deben operar conforme al GDPR.

2.2.3 Reglamento eIDAS 2.0 – Reglamento (UE) 2024/1183

- **Artículo 5a y siguientes:** Cartera de identidad digital europea (EUDI Wallet).
- Aplicable a las credenciales SD-JWT VC y mdoc emitidas por el sistema conforme a los protocolos OpenID4VCI/VP implementados en `src/identity/sd_jwt.rs` y `src/identity/mdoc.rs`.

2.3 Estandares tecnicos

Estandar	Aplicacion
ETSI TS 102 042 / EN 319 401	Politica de TSP, requisitos de auditoria
ETSI EN 319 411-1/2	Politica de CA, perfiles de certificado
FIPS 140-3	Modulo criptografico (<code>crates/pqc_crypto_module/</code>)
ISO/IEC 27001:2022	Sistema de gestion de seguridad de la informacion
ISO/IEC 27701:2019	Extension de 27001 para gestion de privacidad
ISO 19794-2	Formato de datos biometricos (huella dactilar)

Estandar	Aplicacion
SD-JWT VC (IETF draft)	Credenciales verificables con divulgacion selectiva
ISO/IEC 18013-5 (mdoc)	Documentos de identidad movil

3. Responsable del tratamiento

3.1 Identificacion

Campo	Valor
Razon social	[NOMBRE DE LA ENTIDAD OPERADORA]
RUT	[RUT DE LA ENTIDAD]
Domicilio legal	[DIRECCION], Santiago, Chile
Representante legal	[NOMBRE DEL REPRESENTANTE]
Correo electronico de contacto	[privacidad@dominio.cl]
Telefono	[+56 X XXXX XXXX]

3.2 Encargados del tratamiento

El responsable podra designar encargados de tratamiento para funciones especificas. Todo encargado debera:

1. Suscribir un acuerdo de tratamiento de datos que establezca las instrucciones del responsable, las medidas de seguridad exigidas y las obligaciones de confidencialidad.
2. Tratar los datos unicamente conforme a las instrucciones documentadas del responsable.
3. Colaborar con el responsable en el cumplimiento de obligaciones frente a los titulares y la autoridad de control.
4. Al termino de la relacion, devolver o destruir todos los datos personales conforme a las instrucciones del responsable.

3.3 Corresponsables

Cuando Goya Ledger opere en una red multi-nodo (e.g., mediante docker compose con multiples instancias), cada operador de nodo que trate datos personales sera corresponsable en los terminos del articulo 26 GDPR. Las responsabilidades se delimitaran en el acuerdo inter-operadores (docs/policy/ACUERDO-PARTE-CONFIANTE.md).

4. Datos personales tratados

4.1 Datos de identidad del suscriptor

Fuente: Proceso de proofing de la Autoridad de Registro (src/identity/ra.rs, struct IdentityProofing).

Dato	Campo en el sistema	Categoria	Sensible
Nombre legal completo	legal_name	Identificativo	No
RUT (Rol Unico Tributario)	rut	Identificativo	No
DID del suscriptor	did (formato did:goya:{pubkey_hex[..16]})	Seudonimo	No
Metodo de verificacion	method (InPerson, VideoConference, RemoteAutomated)	Operativo	No
Estado de verificacion	status (Pending, Verified, Rejected)	Operativo	No
Marca temporal de solicitud	requested_at	Operativo	No
Marca temporal de resolucio	resolved_at	Operativo	No
DID del oficial RA	resolved_by	Operativo	No
Motivo de rechazo	rejection_reason	Operativo	No

Nota: El correo electronico del suscriptor se recopila durante el proceso de registro pero no forma parte de la estructura IdentityProofing almacenada en la blockchain. Se gestiona fuera de cadena en el sistema de la RA.

4.2 Datos biometricos

Fuente: Proceso de firma electronica avanzada (FEA) (src/signature/mod.rs, struct BiometricEvidence).

Dato	Campo en el sistema	Categoria	Sensible
Tipo de biometrico	evidence_type (BiometricType)	Sensible	Si
Compromiso SHA-256 del template biometrico	commitment (64 caracteres hex)	Sensible	Si
Marca temporal de captura	captured_at	Operativo	No

Dato	Campo en el sistema	Categoria	Sensible
Identificador del dispositivo de captura	capture_device	Operativo	No

Garantía crítica: El sistema jamás almacena ni transmite datos biométricos en bruto. Únicamente se conserva un compromiso criptográfico (hash SHA-256) del template biométrico. El dato biométrico en crudo permanece en el dispositivo del suscriptor y se descarta inmediatamente tras el cálculo del hash. Esta decisión de diseño se documenta explícitamente en el código fuente:

“The commitment is a SHA-256 hash of the raw biometric data. Raw data never enters the system – only commitments are stored.” (src/signature/mod.rs, línea 149-150)

4.3 Claves públicas e identificadores descentralizados (DIDs)

Dato	Descripción	Categoría
Clave pública Ed25519	Clave de firma electrónica simple (FES), 32 bytes	Seudónimo
Clave pública ML-DSA-65	Clave de firma electrónica avanzada (FEA) post-cuántica, 1952 bytes	Seudónimo
DID (did:goya:{pubkey_hex[..16]})	Identificador descentralizado derivado de la clave pública	Seudónimo
Algoritmo de firma	SigningAlgorithm (Ed25519 o MLDSA65)	Operativo
Firma digital	Vec<u8> – 64 bytes (Ed25519) o 3309 bytes (ML-DSA-65), serializada en hex	Operativo

Consideración de privacidad: Los DIDs son pseudónimos. El formato `did:goya:{pubkey_hex[..16]}` utiliza los primeros 16 caracteres hexadecimales de la clave pública, lo que constituye un pseudónimo criptográfico. La vinculación entre un DID y la identidad civil del suscriptor solo existe en los registros de la RA y no es pública.

4.4 Metadatos de auditoría

Fuente: Registro de auditoría (src/audit.rs, struct AuditEntry).

Dato	Campo en el sistema	Categoría
Marca temporal	timestamp	Operativo
Acción realizada	action (AuditAction)	Operativo

Dato	Campo en el sistema	Categoría
Metodo HTTP	method	Operativo
Ruta del endpoint	path	Operativo
Identificador de organizacion	org_id	Identificativo
Direccion IP de origen	source_ip	Identificativo
Codigo de estado HTTP	status_code	Operativo
Identificador de traza	trace_id	Operativo
Duracion en milisegundos	duration_ms	Operativo
Metadatos adicionales	metadata (opcional: altura de bloque, DID, ID de chaincode)	Operativo
Hash de la entrada anterior	previous_hash (SHA-256 hex)	Integridad
Hash de la entrada actual	entry_hash (SHA-256 hex)	Integridad

Cadena de integridad: Cada entrada de auditoria forma parte de una cadena hash (previous_hash -> entry_hash). Este mecanismo garantiza la deteccion de cualquier alteracion del registro, proporcionando evidencia de no repudio conforme a ETSI TS 102 042.

4.5 Certificados X.509 y credenciales digitales

Dato	Descripcion	Publicidad
Certificado X.509	Contiene nombre del suscriptor, clave publica, periodo de validez, numero de serie, nombre del emisor	Publico (por diseno)
Credencial SD-JWT VC	Credencial verificable con divulgacion selectiva; contiene claims del suscriptor protegidos por hashes salados	Semi-publico (divulgacion selectiva)
Documento mdoc (ISO 18013-5)	Documento de identidad movil con campos protegidos por divulgacion selectiva	Semi-publico (divulgacion selectiva)
Listas de revocacion (CRL)	Contienen numeros de serie de certificados revocados	Publico
Respuestas OCSP	Estado de validez de un certificado especifico	Publico

5. Finalidad del tratamiento

Los datos personales se tratan exclusivamente para las siguientes finalidades:

5.1 Finalidades principales

ID	Finalidad	Datos involucrados	Base legal
F-01	Verificacion de identidad del suscriptor previo a la emision de certificados digitales (Ley 19.799, Art. 15)	Identidad del suscriptor, RUT	Obligacion legal
F-02	Emision, renovacion, suspension y revocacion de certificados digitales X.509	Identidad, clave publica, DID	Ejecucion contractual
F-03	Generacion y verificacion de firmas electronicas simples (FES) y avanzadas (FEA)	Claves publicas, firmas, evidencia biometrica	Ejecucion contractual / Obligacion legal
F-04	Emision de credenciales verificables (SD-JWT VC, mdoc)	Identidad, claims del suscriptor	Ejecucion contractual
F-05	Registro de auditoria para cumplimiento normativo (DS 181, ETSI TS 102 042)	Metadatos de auditoria	Obligacion legal
F-06	Gestion del ciclo de vida de identidades descentralizadas (DID)	DIDs, claves publicas	Ejecucion contractual

5.2 Finalidades secundarias

ID	Finalidad	Datos involucrados	Base legal
F-07	Deteccion y prevencion de	Metadatos de auditoria, IPs	Interes legitimo

ID	Finalidad	Datos involucrados	Base legal
	fraude en el uso de certificados		
F-08	Cumplimiento de requerimientos de autoridades competentes	Todos los aplicables	Obligacion legal
F-09	Mejora de la seguridad y resiliencia del sistema	Metadatos de auditoria (anonimizados)	Interes legitimo
F-10	Interoperabilidad con Trust Lists europeas (ETSI TL)	Certificados, metadatos del PSC	Interes legitimo

5.3 Tratamientos expresamente excluidos

El sistema **no** realiza:

- Perfilado automatizado de suscriptores con efectos juridicos.
- Venta, cesion o arrendamiento de datos personales a terceros.
- Tratamiento de datos con fines de marketing o publicidad.
- Toma de decisiones automatizadas que produzcan efectos juridicos sin intervencion humana (el proceso de proofing requiere aprobacion de un oficial RA).

6. Base legal del tratamiento

6.1 Cumplimiento de obligacion legal (Art. 4 Ley 19.628; Art. 6.1.c GDPR)

- La verificacion de identidad es obligatoria para los PSC conforme a la Ley 19.799, Art. 15, y DS 181.
- La conservacion de registros de auditoria es exigida por DS 181, Art. 47, y ETSI TS 102 042.
- El tratamiento de datos en el contexto de la emision de certificados cualificados es requerido por eIDAS, Art. 24.

6.2 Ejecucion de un contrato (Art. 6.1.b GDPR)

- La emision de certificados y credenciales se enmarca en la relacion contractual entre el PSC y el suscriptor, formalizada mediante el Acuerdo de Suscriptor (docs/policy/ACUERDO-SUSCRIPTOR.md).

6.3 Consentimiento explícito para datos sensibles (Art. 7 Ley 19.628; Art. 9.2.a GDPR)

- El tratamiento de datos biométricos (compromisos SHA-256 de plantillas biométricas) para la generación de firma electrónica avanzada (FEA) requiere consentimiento explícito, informado y revocable del suscriptor.
- El consentimiento se recaba al momento de la activación de FEA y se documenta junto con la solicitud de proofing.

6.4 Interés legítimo (Art. 6.1.f GDPR)

- La detección de fraude y la mejora de la seguridad del sistema se basan en el interés legítimo del responsable, previa ponderación con los derechos del titular conforme al artículo 6.1.f GDPR.
 - Se ha realizado la evaluación de ponderación (Legitimate Interest Assessment) con resultado favorable, documentada en los registros internos de cumplimiento.
-

7. Evaluación de impacto en la protección de datos (EIPD)

7.1 Justificación de la necesidad de EIPD

Conforme al artículo 35 del GDPR, es obligatorio realizar una EIPD cuando el tratamiento:

- Utilice nuevas tecnologías (blockchain, criptografía post-cuántica).
- Trate datos biométricos a gran escala (Art. 35.3.b).
- Realice un seguimiento sistemático (registros de auditoría con IPs y timestamps).
- Trate datos que permitan la evaluación de aspectos personales (identidad verificada vinculada a actividad de firma).

Conclusion: La EIPD es obligatoria. El sistema cumple al menos tres de los criterios enumerados en las Directrices WP 248 del Grupo de Trabajo del Artículo 29.

7.2 Descripción sistemática del tratamiento

7.2.1 Naturaleza del tratamiento

Goya Ledger es un sistema de infraestructura de clave pública (PKI) y firma electrónica que opera sobre una cadena de bloques con consenso BFT (HotStuff + DPoS). El sistema:

1. **Recopila** datos de identidad a través del módulo de Autoridad de Registro (src/identity/ra.rs), que implementa tres métodos de verificación: presencial (InPerson), videoconferencia (VideoConference) y automatizado remoto (RemoteAutomated).

2. **Valida** la identidad del suscriptor, incluyendo la verificación del RUT chileno mediante algoritmo módulo 11 (`validate_rut`).
3. **Genera** pares de claves criptográficas (Ed25519 para FES, ML-DSA-65 para FEA) y derivación de DIDs.
4. **Emite** certificados X.509, credenciales SD-JWT VC y documentos mdoc.
5. **Registra** todas las operaciones en un log de auditoría con cadena hash de integridad (`src/audit.rs`).
6. **Almacena** datos en memoria o en RocksDB (`STORAGE_BACKEND`), con cifrado at-rest disponible.
7. **Procesa** compromisos biométricos SHA-256 para firma electrónica avanzada, sin almacenar datos biométricos en bruto.

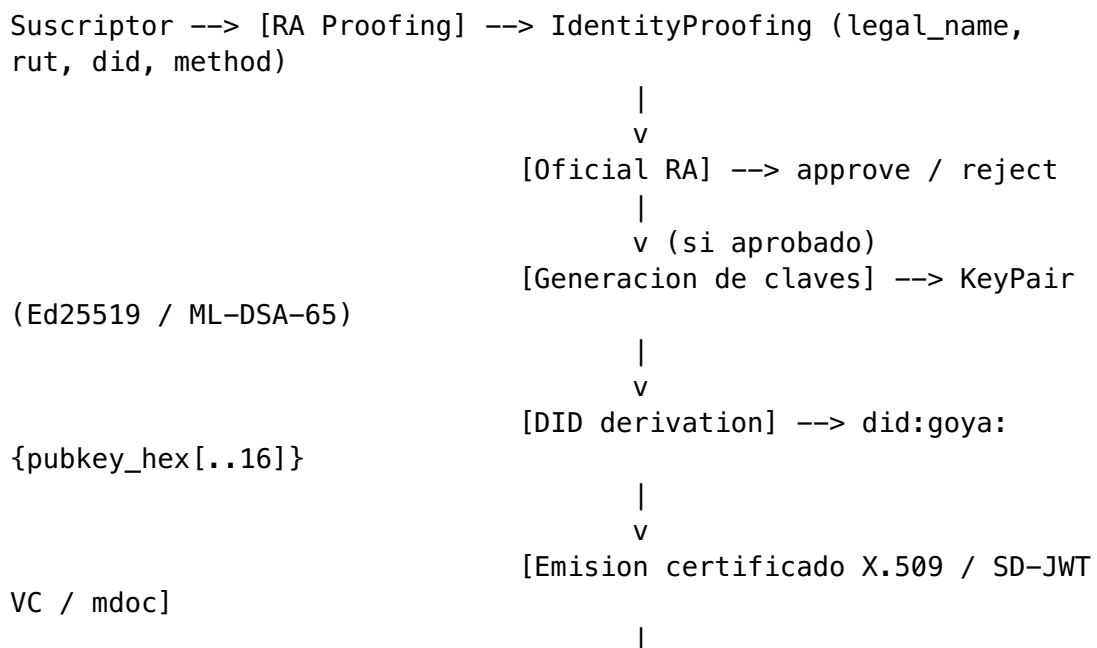
7.2.2 Alcance del tratamiento

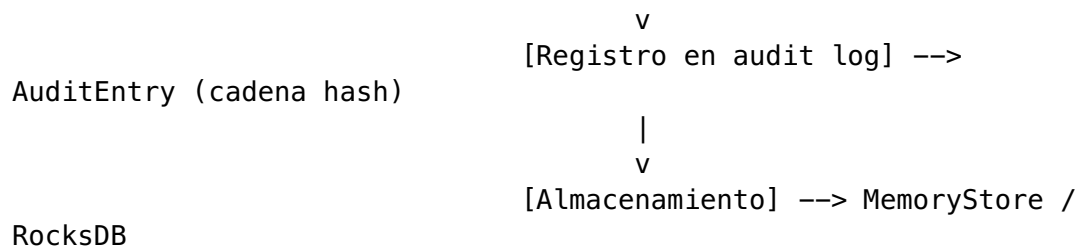
- **Volumen estimado:** Hasta miles de suscriptores por instancia de nodo.
- **Frecuencia:** Continuo (API REST disponible 24/7).
- **Duración:** Registros de auditoría retenidos por 7 años (`DEFAULT_RETENTION_SECS = 7 * 365 * 24 * 3600` en `src/audit_retention.rs`). Certificados X.509 según su periodo de validez. Datos de proofing retenidos mientras el certificado este vigente más el periodo legal de conservación.
- **Area geográfica:** Chile (principal), potencialmente UE (cuando se emitan certificados interoperables via ETSI TL).

7.2.3 Contexto del tratamiento

- El suscriptor proporciona sus datos voluntariamente para obtener un certificado digital y acceder a servicios de firma electrónica.
- La relación se formaliza mediante el Acuerdo de Suscriptor.
- Los datos biométricos se procesan localmente en el dispositivo del suscriptor; solo el compromiso hash ingresa al sistema.
- Menores de edad no son suscriptores objetivo del sistema.

7.2.4 Flujo de datos





7.3 Necesidad y proporcionalidad

7.3.1 Necesidad

Dato	Necesario	Justificacion
Nombre legal	Si	Requerido por Ley 19.799 Art. 15 para vincular certificado a persona natural
RUT	Si	Identificador unico legal en Chile; requerido por DS 181 para verificacion de identidad
Clave publica	Si	Elemento esencial del certificado digital; sin ella no existe firma electronica
DID	Si	Identificador seudonimo que permite operar en el sistema sin exponer la identidad civil
Compromiso biometrico	Si (solo FEA)	Requerido para firma electronica avanzada conforme a Ley 19.799 Art. 2; se trata solo el hash, no el dato en bruto
IP de origen	Si	Requerido para auditoria de seguridad y deteccion de fraude; DS 181 Art. 13
Timestamps	Si	Requeridos para trazabilidad y no repudio; ETSI TS 102 042

7.3.2 Proporcionalidad

- **Minimizacion:** El sistema recopila unicamente los datos estrictamente necesarios para cada finalidad. No se solicitan datos adicionales como direccion fisica, telefono, estado civil u otros.
- **Seudonimizacion:** El uso de DIDs (`did:goya:{pubkey_hex[. . 16]}`) como identificadores primarios en la blockchain permite la operacion del sistema sin exponer la identidad civil del suscriptor.

- **Datos biometricos:** Solo se almacena el compromiso SHA-256 (64 caracteres hex), no el template biometrico original. Esto constituye la minima informacion necesaria para la verificacion biometrica.
- **Divulgacion selectiva:** Las credenciales SD-JWT VC y mdoc permiten al suscriptor revelar unicamente los claims necesarios para cada transaccion, en lugar de toda su informacion de identidad.
- **Datos de auditoria:** Las direcciones IP se registran por obligacion legal pero no se utilizan para perfilado ni seguimiento.

7.3.3 Medidas de proteccion desde el diseno (Privacy by Design)

El sistema implementa los siete principios fundacionales de Privacy by Design (Cavoukian, 2009):

1. **Proactivo, no reactivo:** La arquitectura fue disenada desde su concepcion con privacidad como requisito no funcional.
2. **Privacidad como configuracion predeterminada:** ACL_MODE por defecto limita el acceso; los DIDs ocultan la identidad civil.
3. **Privacidad integrada en el diseno:** La separacion entre datos de identidad (RA, fuera de cadena) y datos operativos (blockchain) es estructural.
4. **Funcionalidad completa:** La seudonimizacion no reduce la funcionalidad del sistema de firma.
5. **Seguridad de extremo a extremo:** TLS 1.3, cifrado at-rest, cadena hash de auditoria.
6. **Visibilidad y transparencia:** Politicas publicadas, codigo fuente auditable.
7. **Respeto por la privacidad del usuario:** Derechos ARCO implementados (Seccion 8).

7.4 Riesgos para los derechos y libertades de los titulares

7.4.1 Riesgos identificados

ID	Riesgo	Probabilidad	Impacto	Nivel
R-01	Acceso no autorizado a datos de identidad del suscriptor (nombre, RUT) almacenados en la RA	Media	Alto	Alto
R-02	Vinculacion de DID seudonimo con identidad civil mediante correlacion de metadatos de auditoria	Baja	Alto	Medio
R-03	Compromiso de claves privadas	Baja	Critico	Alto

ID	Riesgo	Probabilidad	Impacto	Nivel
R-04	del suscriptor o de la CA Uso indebido de compromisos biometricos para re-identificacion	Muy baja	Alto	Medio
R-05	Inmutabilidad de la blockchain impide el ejercicio pleno del derecho de supresion	Alta	Medio	Alto
R-06	Filtracion de direcciones IP y patrones de uso desde los logs de auditoria	Media	Medio	Medio
R-07	Intercepcion de datos en transito entre nodos de la red P2P	Baja	Alto	Medio
R-08	Acceso de autoridades extranjeras a datos de suscriptores chilenos	Baja	Alto	Medio
R-09	Perdida de disponibilidad de datos de auditoria por fallo del almacenamiento	Baja	Medio	Bajo
R-10	Uso de computacion cuantica futura para romper firmas Ed25519	Baja (horizonte 10+ anos)	Critico	Medio

7.4.2 Analisis detallado de riesgos criticos

R-01: Acceso no autorizado a datos de identidad

- **Escenario:** Un atacante obtiene acceso al almacenamiento de la RA y extrae datos de identidad civil vinculados a DIDs.

- **Impacto:** Violacion masiva de privacidad; exposicion de nombre legal y RUT de suscriptores; potencial suplantacion de identidad.
- **Titulares afectados:** Todos los suscriptores con proofing completado.

R-03: Compromiso de claves privadas

- **Escenario:** Compromiso del material criptografico de la CA raiz o de claves de suscriptores.
- **Impacto:** Emision fraudulenta de certificados; firmas falsificadas con valor probatorio; perdida total de confianza en el sistema.
- **Titulares afectados:** Todos los suscriptores y partes confiantes.

R-05: Inmutabilidad vs. derecho de supresion

- **Escenario:** Un suscriptor ejerce su derecho de cancelacion/supresion (ARCO/ GDPR Art. 17), pero los datos estan registrados en bloques inmutables de la blockchain.
- **Impacto:** Imposibilidad tecnica de eliminar ciertos datos; potencial incumplimiento del derecho de supresion.
- **Titulares afectados:** Cualquier suscriptor que solicite la eliminacion de sus datos.

7.5 Medidas de mitigacion

Riesgo	Medida de mitigacion	Riesgo residual
R-01	Control de acceso basado en roles (enforce_acl); cifrado at-rest; segmentacion de datos de RA fuera de cadena	Bajo
R-02	Seudonimizacion mediante DIDs; no indexacion cruzada DID-identidad en blockchain; acceso a vinculacion restringido a oficiales RA autorizados	Bajo
R-03	Ceremonia de claves documentada (docs/policy/PROCEDIMIENTO-CEREMONIA-CLAVES.md); HSM para claves de CA; rotacion de claves; ML-DSA-65 post-cuantico disponible	Bajo
R-04	Solo se almacena hash SHA-256 irreversible; el template biometrico nunca ingresa al sistema; la reconstruccion del dato biometrico original a partir del hash es	Muy bajo

Riesgo	Medida de mitigacion	Riesgo residual
	computacionalmente inviable	
R-05	Arquitectura de datos en dos capas: (1) datos de identidad civil en RA fuera de cadena (eliminables), (2) solo DID's seudonimos en blockchain; revocacion de certificados sin eliminar bloques; politica de derecho al olvido con anonimizacion de datos fuera de cadena	Medio
R-06	Politica de retencion de logs con purga automatica (AuditRetentionPolicy); acceso a logs restringido por ACL; IPs no indexadas para busqueda	Bajo
R-07	TLS 1.3 obligatorio para red P2P (src/network/mod.rs); autenticacion mutua de nodos; cifrado de canal	Bajo
R-08	Datos almacenados en jurisdiccion chilena; Clausulas Contractuales Tipo (CCT) para cualquier transferencia; sin acceso directo a autoridades extranjeras sin proceso legal chileno	Bajo
R-09	Replicacion en multiples nodos (consenso BFT); respaldos periodicos; plan de contingencia (docs/policy/PLAN-CONTINGENCIA.md)	Muy bajo
R-10	Soporte de ML-DSA-65 (FIPS 204) como algoritmo post-cuantico; ruta de migracion criptografica documentada; campo signature_algorithm en toda estructura firmada permite transicion sin romper compatibilidad	Bajo

7.6 Resultado de la evaluacion

Tras la aplicacion de las medidas de mitigacion, el riesgo residual global del tratamiento se clasifica como **ACEPTABLE**, con la siguiente salvedad:

- **R-05 (Inmutabilidad vs. supresion):** Mantiene un riesgo residual **Medio** que se gestiona mediante la arquitectura de dos capas. Se recomienda monitorear la evolucion normativa y jurisprudencial sobre el derecho de supresion en contextos de blockchain.

La EIPD sera revisada:

- Al menos una vez al ano.
 - Ante cualquier cambio significativo en el tratamiento (nuevo tipo de dato, nueva finalidad, cambio tecnologico).
 - Ante cambios normativos relevantes (reforma de la Ley 19.628, nuevas directrices de la autoridad de control).
-

8. Derechos ARCO

8.1 Marco general

Los titulares de datos personales tienen derecho a ejercer los derechos ARCO conforme a la Ley 19.628 (Arts. 12-16) y, cuando aplique, los derechos ampliados del GDPR (Arts. 15-22).

8.2 Derecho de Acceso

Aspecto	Detalle
Contenido	El suscriptor puede solicitar informacion sobre: los datos personales tratados, las finalidades del tratamiento, los destinatarios, los plazos de conservacion, y la existencia de decisiones automatizadas
Canal	Solicitud escrita al correo del DPO o mediante formulario en el portal del suscriptor
Plazo de respuesta	2 dias habiles (Ley 19.628 Art. 12) / 1 mes (GDPR Art. 12.3)
Formato	Copia electronica de los datos en formato estructurado (JSON/PDF)
Costo	Gratuito para la primera solicitud en cada periodo de 12 meses
Implementacion tecnica	Consulta al RaStore para datos de proofing; consulta al AuditLog para

Aspecto	Detalle
	registros de actividad del DID del suscriptor

8.3 Derecho de Rectificacion

Aspecto	Detalle
Contenido	Correccion de datos inexactos o incompletos (e.g., cambio de nombre legal por sentencia judicial)
Procedimiento	Solicitud con documentacion respaldatoria; verificacion por oficial RA; actualizacion en registros fuera de cadena; emision de nuevo certificado si corresponde; revocacion del certificado anterior
Limitacion blockchain	Los datos registrados en bloques inmutables no pueden modificarse. La rectificacion se implementa mediante: (1) actualizacion del registro RA fuera de cadena, (2) revocacion del certificado vinculado al dato incorrecto, (3) emision de nuevo certificado con datos corregidos
Plazo	5 dias habiles / 1 mes (GDPR)

8.4 Derecho de Cancelacion (Supresion)

Aspecto	Detalle
Contenido	Eliminacion de datos personales cuando ya no sean necesarios para la finalidad del tratamiento
Procedimiento	(1) Eliminacion de datos de identidad civil del RaStore (fuera de cadena); (2) revocacion de todos los certificados activos del suscriptor; (3) anonimizacion de entradas de auditoria vinculadas al DID (reemplazo de source_ip por hash, org_id por valor anonimo); (4) conservacion del DID seudonimo en blockchain sin vinculacion a identidad civil
Excepciones	No procede cuando: (a) exista obligacion legal de conservacion (DS 181, Art. 47: 6 anos); (b) los datos sean necesarios para el ejercicio o defensa de reclamaciones legales; (c) existan certificados vigentes no revocados

Aspecto	Detalle
Plazo	2 días hábiles (Ley 19.628) / 1 mes (GDPR)

8.5 Derecho de Oposicion

Aspecto	Detalle
Contenido	El suscriptor puede oponerse al tratamiento basado en interes legitimo (finalidades F-07 y F-09)
Procedimiento	Solicitud motivada al DPO; evaluacion caso a caso; suspension del tratamiento mientras se resuelve
Limitacion	No procede para tratamientos basados en obligacion legal (F-01, F-05, F-08) ni ejecucion contractual (F-02, F-03, F-04, F-06) mientras la relacion contractual este vigente
Plazo	1 mes (GDPR)

8.6 Derecho de Portabilidad (GDPR Art. 20)

Aspecto	Detalle
Contenido	El suscriptor puede recibir sus datos en formato estructurado, de uso comun y lectura mecanica
Formato de exportacion	JSON conforme al esquema de IdentityProofing; certificados X.509 en formato PEM/DER; credenciales SD-JWT VC en formato JWT compacto; documentos mdoc en formato CBOR
Transmision directa	Cuando sea tecnicamente posible, se transmitiran directamente a otro PSC designado por el suscriptor

8.7 Procedimiento general

1. **Recepcion:** La solicitud se recibe por el canal designado y se registra con un numero de seguimiento.
2. **Verificacion de identidad:** Se verifica la identidad del solicitante mediante el mismo nivel de proofing utilizado para su registro (evitando acceso fraudulento a datos de terceros).
3. **Evaluacion:** El DPO evalua la procedencia de la solicitud en un plazo maximo de 5 días hábiles.
4. **Ejecucion:** Si procede, se ejecuta la accion solicitada dentro de los plazos legales.

5. **Notificación:** Se notifica al solicitante del resultado, incluyendo las razones en caso de rechazo total o parcial.
6. **Registro:** Toda solicitud y su resolución se registran en el log de auditoría.

8.8 Recurso ante la autoridad de control

En caso de disconformidad con la respuesta del responsable, el titular puede:

- **Chile:** Presentar un recurso de habeas data ante los tribunales civiles (Ley 19.628, Art. 16).
 - **Union Europea:** Presentar una reclamación ante la autoridad de control competente (GDPR, Art. 77).
-

9. Transferencia internacional de datos

9.1 Principio general

Los datos personales tratados por Goya Ledger se almacenan y procesan principalmente en servidores ubicados en la República de Chile. Cualquier transferencia internacional de datos se somete a las siguientes garantías:

9.2 Transferencias dentro de la red blockchain

Cuando Goya Ledger opera en una red multi-nodo con nodos ubicados en diferentes jurisdicciones:

- Los bloques de la blockchain contienen únicamente DID's seudónimos, firmas y hashes. **No contienen datos de identidad civil** (nombre, RUT).
- La propagación de bloques entre nodos internacionales se considera transferencia de datos seudonimizados, no de datos personales directamente identificables.
- No obstante, se adoptan las Clausulas Contractuales Tipo (CCT) de la Comisión Europea (Decision 2021/914) como garantía adicional.

9.3 Transferencias a la Union Europea

- Chile no cuenta actualmente con una decisión de adecuación de la Comisión Europea conforme al Art. 45 GDPR.
- Las transferencias Chile-UE se amparan en CCT y, cuando aplique, en el consentimiento explícito del suscriptor (Art. 49.1.a GDPR).
- La interoperabilidad con ETSI Trust Lists europeas se limita a la publicación de metadatos del PSC (nombre, certificado de CA, políticas), sin transferencia de datos personales de suscriptores.

9.4 Transferencias a terceros países

- No se realizan transferencias a países sin nivel adecuado de protección sin las garantías apropiadas (CCT, normas corporativas vinculantes, o excepciones del Art. 49 GDPR).

- Se mantiene un registro actualizado de todos los países donde residen nodos de la red.

9.5 Evaluación de impacto de la transferencia (TIA)

Antes de habilitar nodos en nuevas jurisdicciones, se realizará una Evaluación de Impacto de la Transferencia conforme a las recomendaciones 01/2020 del EDPB, considerando:

1. Legislación de vigilancia del país receptor.
2. Acceso de autoridades a datos almacenados.
3. Efectividad de las garantías contractuales.
4. Medidas técnicas complementarias (cifrado, seudonimización).

10. Retención y eliminación de datos

10.1 Política de retención

Tipo de dato	Periodo de retención	Base legal	Implementación técnica
Registros de auditoría	7 años desde la creación de la entrada	DS 181 Art. 47; ETSI TS 102 042	DEFAULT_RETENTION_SECS = 7 * 365 * 24 * 3600 (src/audit_retention.rs)
Datos de identidad (RA)	Vigencia del certificado + 7 años	DS 181 Art. 47	Gestionado por RaStore; eliminación manual tras periodo de retención
Certificados X.509	Vigencia del certificado + 7 años	DS 181; ETSI EN 319 411	Almacenados en cadena; revocación disponible
Credenciales SD-JWT VC	Según exp claim + 1 año	Política interna	Credenciales auto-expirables
Documentos mdoc	Según periodo de validez + 1 año	ISO 18013-5	Gestionado por el suscriptor
Compromisos biométricos	Eliminados tras verificación exitosa	Principio de minimización (GDPR Art. 5.1.c)	Solo se conserva el resultado (pass/fail) de la verificación; el commitment se descarta
DIDs en blockchain	Indefinido (inmutabilidad de la cadena)	Diseño del sistema	DIDs seudónimos; sin vinculación a identidad civil tras ejercicio de cancelación
Direcciones IP en auditoría	7 años (junto con la entrada de auditoría)	DS 181 Art. 47	Sujeto a anonimización anticipada si el titular ejerce derecho de cancelación

10.2 Procedimiento de eliminacion

1. **Identificacion:** El modulo AuditRetentionPolicy (src/audit_retention.rs) verifica periodicamente las entradas cuya antigüedad excede min_retention_secs.
2. **Elegibilidad:** Las entradas solo son elegibles para purga si:
 - Han superado el periodo minimo de retencion.
 - No estan vinculadas a certificados vigentes.
 - No estan sujetas a una retencion legal vigente (litigation hold).
3. **Purga:** Si auto_purge_enabled esta activo, las entradas elegibles se eliminan automaticamente. En caso contrario, un administrador autorizado ejecuta la purga manualmente.
4. **Verificacion:** Se genera una entrada de auditoria registrando la purga (numero de entradas eliminadas, rango de fechas, administrador responsable).

10.3 Eliminacion segura

- Los datos eliminados de RocksDB se sobrescriben mediante el mecanismo de compactacion del motor de almacenamiento.
 - Los datos en memoria (MemoryStore) se liberan y sobrescriben al reiniciar el proceso.
 - Los medios de almacenamiento fisico retirados se destruyen conforme a NIST SP 800-88 Rev. 1 (Guidelines for Media Sanitization).
-

11. Medidas de seguridad

11.1 Medidas tecnicas

11.1.1 Cifrado en reposo (at-rest)

- Algoritmo: **AES-256-GCM** para datos almacenados en disco.
- Gestion de claves: Las claves de cifrado se almacenan separadas de los datos cifrados; rotacion periodica conforme a la politica de claves.
- Ambito: Aplica a STORAGE_BACKEND=rocksdb y al almacenamiento local del cliente liviano (GOYA_DATA_DIR).

11.1.2 Cifrado en transito

- Protocolo: **TLS 1.3** obligatorio para:
 - API REST (puerto configurado por API_PORT, predeterminado 8080).
 - Red P2P (puerto configurado por P2P_PORT, predeterminado 8081).
- En produccion (RUST_BC_ENV=production): se requieren TLS_CERT_PATH y TLS_KEY_PATH.
- Cipher suites: Solo suites AEAD con Perfect Forward Secrecy.

11.1.3 Seudonimizacion

- Todos los suscriptores operan en la blockchain a traves de su DID seudonimo (did:goya:{pubkey_hex[..16]}).

- La vinculacion DID-identidad civil se mantiene exclusivamente en los registros de la RA, con acceso restringido.
- La funcion canonica de derivacion `identity::did::did_from_pubkey_hex()` garantiza la unicidad y consistencia del seudonimo.

11.1.4 Cadena de integridad de auditoria

- Cada `AuditEntry` contiene `previous_hash` y `entry_hash` formando una cadena hash SHA-256.
- Cualquier alteracion de una entrada rompe la cadena y es detectable automaticamente.
- La funcion `canonical_data()` define los campos incluidos en el hash, garantizando la reproducibilidad de la verificacion.

11.1.5 Control de acceso

- **Modelo ACL:** Sistema de control de acceso configurado por `ACL_MODE` (permisivo/restrictivo).
- **Enforcement:** La funcion `enforce_acl` se invoca en cada handler de la API antes de procesar la solicitud.
- **Produccion:** `ACL_MODE=permissive` genera una advertencia; se recomienda modo restrictivo.

11.1.6 Criptografia post-cuantica

- **ML-DSA-65 (FIPS 204):** Disponible como alternativa a Ed25519 para firma electronica avanzada.
- **Modulo criptografico dedicado:** `crates/pqc_crypto_module/` centraliza todas las operaciones criptograficas.
- **Prohibicion de importaciones directas:** El uso de `sha2`, `ed25519_dalek` u otras primitivas fuera del modulo criptografico esta prohibido y verificado por `cargo test --test crypto_boundary`.

11.1.7 Proteccion de claves privadas

- **HSM:** Soporte para modulos de seguridad de hardware (`src/identity/hsm.rs`) para almacenamiento de claves de CA.
- **Ceremonia de claves:** Procedimiento documentado en `docs/policy/PROCEDIMIENTO-CEREMONIA-CLAVES.md`.
- **Recuperacion:** Mecanismo de recuperacion de vault configurado por `VAULT_RECOVERY_SECRET`.

11.2 Medidas organizativas

11.2.1 Gobernanza de acceso

- Principio de minimo privilegio para todos los roles del sistema.
- Segregacion de funciones entre oficiales RA, administradores de sistema y operadores de nodo.
- Revision periodica de permisos de acceso (trimestral).

11.2.2 Gestion de incidentes

- Plan de contingencia documentado (docs/policy/PLAN-CONTINGENCIA.md).
- Procedimiento de notificacion de brechas (Seccion 12).
- Simulacros de incidentes al menos una vez al ano.

11.2.3 Formacion y concienciacion

- Todo el personal con acceso a datos personales recibe formacion anual en proteccion de datos.
- Los oficiales RA reciben formacion especifica sobre tratamiento de datos biometricos y verificacion de identidad.

11.2.4 Auditoria externa

- Auditoria anual de cumplimiento normativo (ETSI EN 319 401).
 - Pruebas de penetracion al menos una vez al ano.
 - Evaluacion de vulnerabilidades continua (cargo audit, cargo deny check).
-

12. Notificacion de brechas de seguridad

12.1 Definicion de brecha

Se entiende por brecha de seguridad de datos personales toda violacion de la seguridad que ocasione la destruccion, perdida o alteracion accidental o ilicita de datos personales, o la comunicacion o acceso no autorizados a dichos datos.

12.2 Plazos de notificacion

Jurisdiccion	Autoridad	Plazo	Base legal
Chile	Subsecretaria de Economia y Empresas de Menor Tamano	24 horas desde la deteccion	DS 181, Art. 38
Union Europea	Autoridad de control competente	72 horas desde el conocimiento	GDPR, Art. 33
Titulares afectados	Notificacion directa al titular	Sin dilacion indebida cuando la brecha entrane alto riesgo	GDPR, Art. 34; buenas practicas DS 181

12.3 Contenido de la notificacion

La notificacion a la autoridad de control incluira:

1. Naturaleza de la brecha (tipo de incidente, vector de ataque).

2. Categorías y número aproximado de titulares afectados.
3. Categorías y número aproximado de registros afectados.
4. Nombre y datos de contacto del DPO.
5. Consecuencias probables de la brecha.
6. Medidas adoptadas o propuestas para remediar la brecha.
7. Medidas adoptadas para mitigar los efectos adversos.

12.4 Procedimiento interno

1. **Detección:** Cualquier empleado o sistema automatizado que detecte una brecha debe reportarla inmediatamente al DPO y al equipo de respuesta a incidentes.
2. **Contención:** Aislar los sistemas afectados. Preservar evidencia forense (`src/forensic.rs`).
3. **Evaluación:** El DPO evalúa si la brecha afecta datos personales y el nivel de riesgo para los titulares.
4. **Notificación regulatoria:** Si la brecha afecta datos personales, notificar a la autoridad dentro de los plazos establecidos.
5. **Notificación a titulares:** Si la brecha entraña alto riesgo, notificar directamente a los titulares afectados.
6. **Remediación:** Corregir la vulnerabilidad, restaurar los datos afectados, reforzar las medidas de seguridad.
7. **Post-incidente:** Documentar el incidente, realizar análisis de causa raíz, actualizar la EIPD si procede.

12.5 Registro de brechas

Se mantiene un registro interno de todas las brechas de seguridad, incluidas aquellas que no requieran notificación a la autoridad, conforme al Art. 33.5 GDPR. El registro incluye: hechos, efectos y medidas correctivas.

13. Delegado de protección de datos

13.1 Designación

Conforme al Art. 37 GDPR, se designa un Delegado de Protección de Datos (DPO) dado que:

- El tratamiento es realizado por una autoridad u organismo público (cuando aplique).
- Las actividades principales consisten en operaciones de tratamiento que requieren una observación habitual y sistemática de interesados a gran escala.
- Las actividades principales consisten en el tratamiento a gran escala de categorías especiales de datos (biométricos).

13.2 Datos de contacto

Campo	Valor
Nombre	[NOMBRE DEL DPO]

Campo	Valor
Correo electronico	[dpo@dominio.cl]
Telefono	[+56 X XXXX XXXX]
Direccion postal	[DIRECCION], Santiago, Chile

13.3 Funciones

El DPO tiene las siguientes funciones (Art. 39 GDPR):

1. Informar y asesorar al responsable y a los empleados sobre las obligaciones de proteccion de datos.
2. Supervisar el cumplimiento del GDPR, la Ley 19.628 y las politicas internas de privacidad.
3. Asesorar sobre la evaluacion de impacto (EIPD) y supervisar su aplicacion.
4. Cooperar con la autoridad de control y actuar como punto de contacto.
5. Gestionar las solicitudes de ejercicio de derechos ARCO.
6. Mantener el registro de actividades de tratamiento (Anexo A).

13.4 Independencia

El DPO:

- Reporta directamente al nivel directivo mas alto de la organizacion.
- No recibe instrucciones sobre el ejercicio de sus funciones.
- No puede ser destituido ni sancionado por el desempeno de sus funciones.
- Dispone de los recursos necesarios para el ejercicio de sus funciones.

14. Disposiciones finales

14.1 Vigencia y revision

- Esta politica entra en vigencia en la fecha de emision indicada en el encabezado.
- Se revisara al menos una vez al ano o ante cambios significativos en el tratamiento, la tecnologia o la normativa aplicable.
- Las versiones anteriores se conservan en el sistema de control de versiones (Git) para trazabilidad.

14.2 Aprobacion

Rol	Nombre	Fecha	Firma
Responsable del tratamiento	[NOMBRE]	[FECHA]	_____
Delegado de proteccion de datos	[NOMBRE]	[FECHA]	_____
Director de tecnologia	[NOMBRE]	[FECHA]	_____
Asesor juridico	[NOMBRE]	[FECHA]	_____

14.3 Control de cambios

Version	Fecha	Autor	Descripcion del cambio
1.0	2026-08-13	[AUTOR]	Version inicial

Anexo A – Registro de actividades de tratamiento

Conforme al Art. 30 GDPR, se mantiene el siguiente registro de actividades de tratamiento:

A.1 Actividad: Verificacion de identidad (RA Proofing)

Campo	Valor
Responsable	[NOMBRE DE LA ENTIDAD]
Finalidad	F-01: Verificacion de identidad conforme a Ley 19.799 Art. 15
Categorias de interesados	Suscriptores solicitantes de certificados digitales
Categorias de datos	Nombre legal, RUT, DID, metodo de verificacion, estado, timestamps
Destinatarios	Oficiales RA autorizados; autoridades competentes (bajo requerimiento legal)
Transferencias internacionales	No (datos mantenidos en RA local)
Plazo de conservacion	Vigencia del certificado + 7 anos
Medidas de seguridad	Cifrado at-rest (AES-256-GCM), control de acceso (ACL), auditoria
Modulos del sistema	src/identity/ra.rs (IdentityProofing, RaStore)

A.2 Actividad: Tratamiento de datos biometricos (FEA)

Campo	Valor
Responsable	[NOMBRE DE LA ENTIDAD]
Finalidad	F-03: Generacion de firma electronica avanzada
Categorias de interesados	Suscriptores con FEA habilitada
Categorias de datos	Tipo de biometrico, compromiso SHA-256, timestamp de captura, dispositivo
Base legal	Consentimiento explicito (Art. 9.2.a GDPR; Art. 7 Ley 19.628)
Destinatarios	

Campo	Valor
	Sistema interno (verificacion automatizada); no se comparte con terceros
Transferencias internacionales	No
Plazo de conservacion	Eliminado tras verificacion exitosa
Medidas de seguridad	Solo hash SHA-256 irreversible; dato en bruto nunca ingresa al sistema
Modulos del sistema	src/signature/mod.rs (BiometricEvidence)

A.3 Actividad: Emision de certificados y credenciales

Campo	Valor
Responsable	[NOMBRE DE LA ENTIDAD]
Finalidad	F-02, F-04: Emision de certificados X.509, SD-JWT VC, mdoc
Categorias de interesados	Suscriptores verificados
Categorias de datos	Nombre, clave publica, DID, periodo de validez, claims
Destinatarios	Partes confiantes (verificadores); repositorios publicos de certificados
Transferencias internacionales	Posible (ETSI TL, interoperabilidad europea)
Plazo de conservacion	Vigencia del certificado + 7 anos
Medidas de seguridad	Firma digital del emisor, cadena de confianza X.509, revocacion
Modulos del sistema	src/pki.rs, src/identity/ sd_jwt.rs, src/identity/mdoc.rs

A.4 Actividad: Registro de auditoria

Campo	Valor
Responsable	[NOMBRE DE LA ENTIDAD]
Finalidad	F-05: Registro de auditoria para cumplimiento normativo
Categorias de interesados	Todos los usuarios del sistema (suscriptores, administradores, partes confiantes)
Categorias de datos	Timestamps, acciones, metodos HTTP, rutas, IPs, org_id, trace_id, duracion
Destinatarios	Administradores autorizados; auditores externos; autoridades (bajo requerimiento)
Transferencias internacionales	No (almacenamiento local)

Campo	Valor
Plazo de conservacion	7 anos (DEFAULT_RETENTION_SECS)
Medidas de seguridad	Cadena hash SHA-256 (tamper-evident), ACL, cifrado at-rest
Modulos del sistema	src/audit.rs (AuditEntry), src/audit_retention.rs (AuditRetentionPolicy)

A.5 Actividad: Gestion de identidades descentralizadas (DID)

Campo	Valor
Responsable	[NOMBRE DE LA ENTIDAD]
Finalidad	F-06: Gestion del ciclo de vida de DIDs
Categorias de interesados	Todos los suscriptores
Categorias de datos	DIDs (did:goya:{pubkey_hex[..16]}), claves publicas, algoritmos de firma
Destinatarios	Red blockchain (seudonimizado); partes confiantes (verificacion de firma)
Transferencias internacionales	Posible (nodos en multiples jurisdicciones)
Plazo de conservacion	Indefinido (inmutabilidad de blockchain)
Medidas de seguridad	Seudonimizacion por diseno; clave privada bajo control exclusivo del suscriptor
Modulos del sistema	src/identity/did.rs, src/identity/mod.rs

Anexo B – Matriz de riesgos

B.1 Criterios de evaluacion

Probabilidad:

Nivel	Descripcion	Frecuencia estimada
Muy baja	Evento extremadamente improbable	< 1 vez en 10 anos
Baja	Evento improbable pero posible	1 vez en 5-10 anos
Media	Evento que podria ocurrir	1 vez en 1-5 anos
Alta	Evento probable	> 1 vez al ano

Impacto:

Nivel	Descripcion
Bajo	Inconveniente menor para el titular; sin consecuencias legales significativas
Medio	Perjuicio moderado; posible dano reputacional o discriminacion limitada
Alto	Perjuicio grave; posible suplantacion de identidad, perdida financiera, o discriminacion
Critico	Perjuicio muy grave e irreversible; compromiso masivo de identidades

B.2 Matriz de riesgo inherente (antes de mitigacion)

ID	Riesgo	Probabilidad	Impacto	Nivel inherente
R-01	Acceso no autorizado a datos de identidad (RA)	Media	Alto	Alto
R-02	Vinculacion DID-identidad civil por correlacion	Baja	Alto	Medio
R-03	Compromiso de claves privadas (CA/suscriptor)	Baja	Critico	Alto
R-04	Re-identificacion por compromiso biometrico	Muy baja	Alto	Medio
R-05	Inmutabilidad blockchain vs. derecho de supresion	Alta	Medio	Alto
R-06	Filtracion de IPs y patrones de uso	Media	Medio	Medio
R-07	Intercepcion de datos en transito (P2P)	Baja	Alto	Medio
R-08	Acceso de autoridades extranjeras	Baja	Alto	Medio
R-09		Baja	Medio	Bajo

ID	Riesgo	Probabilidad	Impacto	Nivel inherente
R-10	Perdida de disponibilidad de auditoria Computacion cuantica vs. Ed25519	Baja	Critico	Medio
R-11	Error humano del oficial RA en proofing	Media	Alto	Alto
R-12	Abuso de privilegios por administrador	Baja	Critico	Alto

B.3 Matriz de riesgo residual (despues de mitigacion)

ID	Riesgo	Mitigaciones aplicadas	Nivel residual
R-01	Acceso no autorizado a datos RA	ACL, cifrado at-rest, segmentacion fuera de cadena	Bajo
R-02	Vinculacion DID-identidad civil	Seudonimizacion, acceso restringido a RA	Bajo
R-03	Compromiso de claves privadas	HSM, ceremonia de claves, ML-DSA-65	Bajo
R-04	Re-identificacion biometrica	Solo hash SHA-256 irreversible	Muy bajo
R-05	Inmutabilidad vs. supresion	Arquitectura dos capas, anonimizacion fuera de cadena	Medio
R-06	Filtracion de IPs	Retencion con purga, ACL sobre logs	Bajo
R-07	Intercepcion en transito	TLS 1.3, autenticacion mutua	Bajo
R-08	Acceso autoridades extranjerias	Datos en Chile, CCT, proceso legal requerido	Bajo
R-09	Perdida de auditoria	Replicacion BFT, respaldos, plan de contingencia	Muy bajo

ID	Riesgo	Mitigaciones aplicadas	Nivel residual
R-10	Computacion cuantica	ML-DSA-65 disponible, ruta de migracion	Bajo
R-11	Error humano RA	Doble verificacion, formacion, validacion automatica RUT	Bajo
R-12	Abuso de privilegios	Segregacion de funciones, auditoria de acceso, minimo privilegio	Bajo

B.4 Mapa de calor

	Bajo	Medio	Alto	Critico
Alta		R-05(res)		
Media			R-01, R-11	
Baja		R-02, R-06	R-07, R-08	R-03, R-12
Muy baja			R-04	R-10

Leyenda: R-XX(res) indica nivel inherente; todos los demas son riesgo inherente.

Tras mitigacion, la mayoría se desplazan a Bajo o Muy bajo.

Anexo C – Glosario

Termino	Definicion
ARCO	Derechos de Acceso, Rectificacion, Cancelacion y Oposicion conforme a la Ley 19.628
CA	Autoridad de Certificacion (Certificate Authority)
CCT	Clausulas Contractuales Tipo (Standard Contractual Clauses)
CRL	Lista de Revocacion de Certificados (Certificate Revocation List)
DID	

Termino	Definicion
	Identificador Descentralizado (Decentralized Identifier)
DPO	Delegado de Proteccion de Datos (Data Protection Officer)
DS 181	Decreto Supremo 181, Reglamento de la Ley 19.799
EDPB	Comite Europeo de Proteccion de Datos (European Data Protection Board)
EIPD	Evaluacion de Impacto en la Proteccion de Datos (Data Protection Impact Assessment / DPIA)
eIDAS	Electronic Identification, Authentication and Trust Services (Reglamento UE 910/2014)
FEA	Firma Electronica Avanzada
FES	Firma Electronica Simple
GDPR	Reglamento General de Proteccion de Datos (Reglamento UE 2016/679)
HSM	Modulo de Seguridad de Hardware (Hardware Security Module)
mdoc	Documento de identidad movil conforme a ISO/IEC 18013-5
ML-DSA-65	Module-Lattice-Based Digital Signature Algorithm, nivel de seguridad 3 (FIPS 204)
OCSP	Protocolo de Estado de Certificado en Linea (Online Certificate Status Protocol)
PKI	Infraestructura de Clave Publica (Public Key Infrastructure)
PSC	Prestador de Servicios de Certificacion
RA	Autoridad de Registro (Registration Authority)
RUT	Rol Unico Tributario (identificador tributario chileno)
SD-JWT VC	Selective Disclosure JSON Web Token Verifiable Credential
TLS	Transport Layer Security
TSP	Trust Service Provider (Prestador de Servicios de Confianza)

Fin del documento.